

10PEARLS

10Shine Internship Program

Assignment No. 1

Requirement Analysis and User Story Writing

Project: Online Book Store

Domain: Quality Assurance (Manual + Automation)

Submitted by: **Muhammad Faizan Anwar**
QA Intern – 10Shine Cohort

1. Refined User Requirements & JTBD Analysis

To build a product users actually need, we look beyond demographics and understand the 'jobs' users are hiring this bookstore to do. The Job-to-Be-Done (JTBD) framework centers on desired outcomes rather than feature lists.

JTBD Type	Description
Primary (Functional)	Users want to quickly find, evaluate, and purchase specific books or textbooks without visiting a physical store.
Secondary (Emotional)	Users expect the platform to feel trustworthy, ensuring personal and financial data is safe during every transaction.

1.1 Key User Preferences & Expectations

- Passwordless, frictionless login via email magic links for ease of access.
- Intuitive categorization (Fiction, Academic, Best Sellers) and robust search filters (Author, ISBN, Price Range, Genre).
- Real-time inventory visibility — e.g., 'In Stock', 'Only 2 Left!', 'Back-ordered'.
- Responsive experience across mobile, tablet, and desktop viewports.
- Transparent checkout with clear cost breakdowns (subtotal, tax, shipping).

2. Functional Requirements (FR)

Functional requirements define the specific behaviors and operations the system must perform to meet user and business goals.

ID	Module	Description
FR-01	Authentication & Security	The system shall allow users to register and log in via a secure, time-sensitive email magic link. The flow must use One-Time Passwords (OTPs) for new device verification and support optional Two-Factor Authentication (2FA) from account settings.
FR-02	Product Catalog	The system shall display a dynamic catalog showing book titles, high-resolution cover images, authors, ISBNs, prices, stock status, and aggregated user ratings.
FR-03	Search & Filter Engine	The system shall provide a full-text search bar queryable by Title, Author, ISBN, or Keyword, complemented by faceted filters for Price Range, Genre, Rating, and Availability.
FR-04	Shopping Cart	The system shall allow users to add items to a persistent cart, modify quantities, remove items, and view a dynamically calculated total including applicable taxes and shipping fees.
FR-05	Secure Checkout	The system shall process payments via integrated payment gateways. It must cryptographically verify payment success against the authenticated user's account state before confirming and finalizing an order.
FR-06	Account Management	The system shall provide a user dashboard to view and track active orders, browse complete purchase history, and manage multiple saved shipping addresses.
FR-07	Admin Dashboard	The system shall provide a secure admin panel accessible only to authorized admin users. Admins shall be able to upload new books, update existing book details and inventory levels, manage user accounts, and view platform-wide sales reports and order analytics.

3. Non-Functional Requirements (NFR)

Non-functional requirements define the quality attributes, constraints, and system characteristics that govern how the system performs its functions.

ID	Category	Requirement
NFR-01	Performance	Homepage and search results must load within 2.0 seconds on a standard broadband connection (measured via Lighthouse / WebPageTest).
NFR-02	Security	All user secrets must be securely hashed (bcrypt/Argon2). Payment data transmitted over TLS 1.3, compliant with PCI-DSS standards. Strict rate limiting enforced on all authentication, OTP, and checkout endpoints to prevent brute-force and credential stuffing attacks.
NFR-03	Scalability	The platform must dynamically scale to support up to 5,000 concurrent user sessions and manage a catalog of 100,000+ books without degrading database query response times by more than 15%.
NFR-04	Usability & Accessibility	The interface must be fully responsive across mobile, tablet, and desktop viewports, conforming to WCAG 2.1 Level AA accessibility standards (color contrast, keyboard navigation, screen-reader support).

4. User Stories & Acceptance Criteria (Gherkin Format)

User stories are written from the user's perspective using the standard template. Each story is accompanied by Behavior-Driven Development (BDD) Gherkin acceptance criteria, making them directly ready for test automation.

Epic 1: Authentication & Security

User Story: As a new customer, I want to log in using a secure link and OTP sent to my email, so that I do not have to remember a password and my account is protected from brute-force attacks.

Acceptance Criteria (Gherkin)

Feature: Secure Authentication and Rate Limiting

Scenario: Successful login via email magic link

```
Given the user requests a login link for "user@bookstore.com"
When the user clicks the magic link in their email within 15 minutes
And the user enters the correct 6-digit OTP provided in the email
Then the system should authenticate the user
And the user should be redirected to their account dashboard
```

Scenario: Magic link expires after 15 minutes

```
Given the user requests a login link for "user@bookstore.com"
When the user clicks the magic link after 15 minutes have elapsed
Then the system should reject the link
And display the message "This link has expired. Please request a new one."
```

Scenario: Rate limiting triggered on login endpoint

```
Given the user is on the login page
When the user requests a login link 6 times within 1 minute
Then the system should block the 6th request
And display "Too many requests. Please try again in 5 minutes."
```

Scenario: Invalid OTP entry

```
Given the user has received a valid magic link
When the user enters an incorrect 6-digit OTP 3 consecutive times
Then the system should invalidate the magic link session
And display "Too many failed attempts. Please request a new link."
```

Scenario: Invalid email format on login

```
Given the user is on the login page
When the user enters an invalidly formatted email (e.g., user@.com)
Then the system should not send a magic link
And display a validation error "Please enter a valid email address."
```

Scenario: Admin attempts to access user-only page

```
Given an admin is logged into the admin dashboard
When the admin navigates to a customer account page directly via URL
Then the system should block access
And redirect to the admin dashboard with error "Unauthorized access."
```

Epic 2: Catalog & Search

User Story: As a book enthusiast, I want to search for books by specific authors and filter by price, so that I can easily find reading material that fits my budget.

Acceptance Criteria (Gherkin)

Feature: Book Search and Filtering

Scenario: Search by keyword returns relevant results

Given the user is on the homepage

When the user types "Harry Potter" in the search bar and presses Enter

Then the results page should display only books matching the keyword

And each result should show title, author, price, and cover image

Scenario Outline: Filter search results by Price Range

Given the user is viewing the search results page for "Fiction"

When the user applies a price filter of <min_price> to <max_price>

Then the system should only display books priced within <expected_range>

Examples:

min_price	max_price	expected_range
\$10	\$20	\$10.00 - \$20.00
\$50	\$100	\$50.00 - \$100.00
\$0	\$5	\$0.00 - \$5.00

Scenario: No results found

Given the user is on the search page

When the user searches for a term with no matching books

Then the system should display "No results found. Try a different search term."

And suggest related categories or popular titles

Epic 3: Shopping Cart & Secure Checkout

User Story: As a **registered customer**, I want to **securely enter my payment details during checkout**, so that I can **finalize my purchase without fear of data theft**.

Acceptance Criteria (Gherkin)

Feature: Secure Checkout Processing

Background:

Given the user is logged into their account

And the user has at least one book in their shopping cart

Scenario: Successful payment processing and user verification

Given the user is on the Checkout payment page

When the user enters valid credit card details

And the user clicks the "Place Order" button

Then the system should verify the payment against the user's account state

And the payment should be processed successfully

And the user should be redirected to the "Order Confirmation" page

And a confirmation email should be sent to the user's registered address

Scenario: Payment declined by gateway

Given the user is on the Checkout payment page

When the user enters invalid or declined credit card details

And clicks "Place Order"

Then the system should not place the order

And display "Payment declined. Please check your card details or try another payment method."

And the cart contents should remain intact

Scenario: Network failure during payment processing

Given the user has submitted a valid payment

When a network timeout occurs before the gateway responds

Then the system should not duplicate the charge

And inform the user to check their order status under Account > Orders

Epic 4: Account Management

User Story: As a **returning customer**, I want to **view my order history and manage my saved addresses**, so that **I can track deliveries and reorder previous purchases quickly**.

Acceptance Criteria (Gherkin)

Feature: User Account Dashboard

Scenario: View order history

Given the user is on their Account Dashboard

When the user navigates to the "Order History" section

Then the system should display a list of past orders

And each order entry should show order ID, date, items, total, and status

Scenario: Add a new shipping address

Given the user is in the "Saved Addresses" section

When the user fills in a valid new address and clicks "Save"

Then the new address should appear in their saved address list

And be available for selection during the next checkout

Epic 5: Admin Dashboard

User Story: As an **admin**, I want to **manage the book catalog and view sales data**, so that **I can keep inventory accurate and monitor platform performance**.

Acceptance Criteria (Gherkin)

Feature: Admin Dashboard Access and Controls

Scenario: Admin uploads a new book

Given the admin is logged into the admin dashboard

When the admin fills in title, author, ISBN, price, and uploads a cover image

And clicks "Publish Book"

Then the book should appear in the public catalog within 60 seconds

And the system should log the upload action with a timestamp

Scenario: Non-admin user attempts to access admin dashboard

Given a regular customer is logged in

When the user navigates to "/admin/dashboard" directly

Then the system should return a 403 Forbidden response

And display "You do not have permission to access this page."

Scenario: Admin updates inventory for an existing book

Given the admin is on the book management page

When the admin changes the stock quantity of a book and saves

Then the updated inventory count should reflect immediately on the product listing page

5. Sprint Planning Submission

The following Agile Sprint Plan organizes the identified user stories into a prioritized, actionable iteration. The goal is to deliver a Minimum Viable Product (MVP) that covers the core user journey from authentication through to purchase.

Attribute	Value	Notes
Sprint Goal	MVP Delivery	Enable a user to securely authenticate, browse the catalog, and complete a verified transaction.
Duration	2 Weeks	Sprint 1 — Foundation Sprint

5.1 Backlog Prioritization (MoSCoW)

Priority	Category	Items
Must-Have	High Priority	Secure Authentication & Rate Limiting (FR-01, NFR-02), Basic Catalog & Search (FR-02, FR-03), Shopping Cart & Checkout (FR-04, FR-05)
Should-Have	Medium Priority	2FA implementation, Faceted filtering (price/rating/genre), Order History Dashboard (FR-06)
Could-Have	Low Priority	Personalized book recommendations, Wishlist functionality, Social sharing
Won't-Have	Out of Scope	Book rental/subscription model, Mobile native apps, AI-based reading companion

5.2 QA Action Items for Sprint 1

- Draft Manual Test Cases based on all Gherkin scenarios in Section 4.
- Identify and document Edge Cases — e.g., OTP bypass attempts, network drops during payment, empty cart checkout.
- Prepare Automation Framework skeleton (Selenium/Cypress) targeting high-priority authentication and checkout flows.
- Set up test environments: staging server, test payment gateway credentials (Stripe test mode), dummy user accounts.
- Define Test Entry & Exit Criteria for Sprint 1 and document in the Test Plan.
- Conduct Exploratory Testing on authentication flow once dev builds are available.
- Define role-based test suites separating **Customer**, **Guest**, and **Admin** user flows to ensure full role coverage.
- Create a dedicated **Negative Test Cases** register documenting invalid inputs, boundary values, and unauthorized access attempts for all epics.

5.3 Definition of Done (DoD)

- All Gherkin scenarios for the story pass in automation (or manually verified if automation not yet available).
- No critical or high-severity defects remain open.
- Code reviewed and merged to the main branch.
- Product Owner has reviewed and accepted the story.
- Documentation updated (API docs, test cases).

6. Edge Cases & Risk Identification

The following edge cases were identified during requirement analysis and must be addressed in the test plan to ensure robustness and security of the system.

Area	Edge Case	Risk	Mitigation
Auth	User submits expired magic link	Unauthorized session creation	Validate timestamp server-side; reject links > 15 min old
Auth	OTP entered 3+ times incorrectly	Brute-force OTP guessing	Invalidate session after 3 failures; log event for security audit
Auth	Rate limit bypass via IP rotation	Credential stuffing attack	Rate limit by email + device fingerprint, not just IP
Auth	User enters malformed email format (e.g., "abc@")	Magic link sent to invalid address, silent failure	Client-side + server-side regex validation before processing
Admin	Regular user accesses admin URL directly	Unauthorized data exposure or modification	Server-side role check on every admin route; return 403 if role != admin
Admin	Admin deletes a book that is in an active order	Order record becomes orphaned / broken	Soft-delete only; retain book record linked to historical orders
Search	Search with special characters or SQL injection	Database query errors / SQLi	Sanitize all inputs; use parameterized queries / ORM
Cart	Item goes out of stock while in cart	User attempts to purchase unavailable item	Re-validate stock at checkout time; display clear out-of-stock notice
Checkout	Network timeout mid-payment	Double charge risk	Idempotency keys on payment API; retry logic with duplicate check
Checkout	Cart total manipulated via client-side request	Underpayment / fraud	Always recalculate total server-side; never trust client-submitted price